

WEB APPLICATION SECURITY REVIEW & VULNERABILITY ANALYSIS

Security Audit Report

Prepared By: Lakshmi Subhaja Kari

Qualification: B.Tech – Cybersecurity

Assessment Role: Junior Cybersecurity Analyst

Assessment Type: Authorized Web Application Security Assessment

Year: 2026

1. Executive Summary

This report presents the results of an authorized web application security assessment conducted in an isolated VMware laboratory environment.

The assessment focused on the Damn Vulnerable Web Application (DVWA) hosted on a Metasploitable 2 virtual machine with the target IP address 192.168.23.129.

The assessment included host discovery, service enumeration, application mapping, authentication review, session management review, HTTP traffic analysis, web server enumeration, directory enumeration, and controlled testing for selected web application vulnerabilities.

Several security weaknesses were identified during web server and resource enumeration. The most significant observations included outdated Apache and PHP versions, exposed phpMyAdmin and phpinfo resources, directory indexing, enabled HTTP TRACE functionality, and missing recommended HTTP security headers.

Controlled tests for reflected XSS, stored XSS, and SQL Injection did not provide sufficient evidence to confirm those vulnerabilities during the assessment. The file upload functionality was reviewed but the test was not completed; therefore, no file-upload vulnerability is claimed.

The assessment demonstrates the importance of maintaining supported software versions, reducing unnecessary application exposure, applying secure server configuration, protecting administrative interfaces, and continuously validating web application security.

2. Project Objectives

The primary objectives of this assessment were:

- To understand the architecture and functionality of the target web application.
- To identify exposed web services and resources.
- To review authentication and session behavior.
- To analyze HTTP requests and responses using Burp Suite.
- To identify potential web server configuration weaknesses.
- To enumerate accessible directories and files.
- To test selected OWASP Top 10 vulnerability categories.
- To assess the security risk associated with identified findings.
- To map findings to relevant OWASP categories.
- To provide practical security recommendations.
- To document the assessment using screenshots and technical evidence.

3. Scope

3.1 In-Scope Systems

The assessment was performed against the intentionally vulnerable laboratory environment:

Target IP: 192.168.23.129

Application: Damn Vulnerable Web Application (DVWA)

Target System: Metasploitable 2

Network: VMware Host-Only isolated network

The primary web services reviewed were HTTP services exposed on ports 80 and 8180.

3.2 Out-of-Scope Systems

The following were outside the scope:

- Internet-facing systems
- Third-party systems
- Unauthorized websites
- Personal systems
- Destructive testing
- Denial-of-service testing
- Automated password attacks
- Systems without explicit authorization

4. Testing Environment

Component	Details
Assessment OS	Kali Linux
Target OS	Metasploitable 2
Web Application	DVWA
Virtualization	VMware Workstation
Network	Host-Only Network
Target IP	192.168.23.129
Browser	Firefox
Proxy	Burp Suite
Web Enumeration	Nikto, Gobuster
Network Scanner	Nmap

5. Tools Used

Nmap

Used for host discovery and service/version enumeration.

Burp Suite

Used for HTTP traffic interception, request analysis, authentication review, and session management review.

Nikto

Used for web server enumeration and identification of server configuration and information-disclosure observations.

Gobuster

Used for directory and resource enumeration.

DVWA

Used as the intentionally vulnerable web application for controlled security testing.

Firefox

Used to access and interact with the target web application.

6. Methodology

The assessment followed a structured security testing methodology:

1. Reconnaissance
2. Host discovery
3. Service enumeration
4. Application mapping
5. Authentication review
6. Session management review
7. HTTP traffic analysis
8. Web server enumeration
9. Directory enumeration
10. Controlled vulnerability testing
11. OWASP mapping
12. Risk assessment
13. Security recommendations
14. Documentation

All testing was conducted within the authorized isolated laboratory environment.

7. Host Discovery – Nmap

The following Nmap command was used:

```
nmap -sn 192.168.23.0/24
```

The scan identified multiple active hosts within the authorized host-only network, including the target system:

192.168.23.129

The target was confirmed to be reachable and was selected for further security assessment.

Evidence: 01_host_discovery_nmap.png

8. Service Enumeration – Nmap

A service and version detection scan was performed using:

```
nmap -sV 192.168.23.129
```

The scan identified several network services.

For the web application assessment, the important services were:

- Port 80 – Apache HTTP Server 2.2.8
- Port 8180 – Apache Tomcat/Coyote JSP 1.1

The HTTP service on port 80 was selected as the primary target for further web application enumeration and security analysis.

Evidence: 02_service_version_scan.png

9. DVWA Application Understanding

The target application was identified as Damn Vulnerable Web Application (DVWA).

DVWA provides several modules for controlled security testing, including:

- Brute Force

- Command Execution
- CSRF
- File Inclusion
- SQL Injection
- SQL Injection (Blind)
- File Upload
- XSS Reflected
- XSS Stored
- DVWA Security
- PHP Info

The DVWA security level was configured to **Low** for controlled laboratory testing.

Evidence: 03_dvwa_login.png

Evidence: 04_dvwa_security_level_low.png

Evidence: 05_dvwa_application_mapping.png

10. Authentication Assessment

The authentication functionality was reviewed using controlled valid and invalid login attempts.

A valid administrator credential was successfully accepted by the application.

An intentionally incorrect password was rejected.

The results demonstrated the expected difference between successful and unsuccessful authentication attempts.

No automated password attack was performed.

Therefore, no specific authentication vulnerability was confirmed during this assessment.

Evidence: 07_authentication_valid.png

Evidence: 08_authentication_invalid.png

Result

Status: Informational – No vulnerability confirmed.

11. Session Management Assessment

Burp Suite HTTP history was reviewed while navigating the authenticated application.

The review focused on:

- Session identifiers
- Cookie usage
- HTTP request headers
- Cookie security attributes
- Secure attribute
- HttpOnly attribute
- SameSite attribute

Actual session values were excluded from the documented evidence to prevent disclosure of active authentication information.

Result

Status: Informational – No specific session-management vulnerability confirmed.

Evidence: 09_session_management_burp.png

12. Burp Suite HTTP Traffic Analysis

Burp Suite was configured as an intercepting proxy between Firefox and the authorized DVWA application.

The HTTP history was reviewed to understand:

- HTTP methods
- URLs
- Request parameters
- Headers
- Cookies
- Server responses
- Application request flow

Burp Suite provided visibility into the communication between the browser and the application and supported authentication and session analysis.

Evidence: 06_burp_http_history.png

13. Web Server Enumeration – Nikto

Nikto was executed against the authorized target using:

```
nikto -h http://192.168.23.129
```

The scan identified several security observations.

Key observations

- Apache 2.2.8 detected
- PHP 5.2.4 detected
- Directory indexing enabled
- /icons/ directory accessible
- /doc/ directory indexing identified
- /test/ directory identified
- phpinfo.php accessible
- phpMyAdmin resource exposed
- HTTP TRACE enabled
- Several recommended security headers were missing

The outdated Apache and PHP versions represent significant maintenance and security concerns because they are legacy software versions.

The exposed configuration and administrative resources may disclose useful information to an attacker.

Evidence: 10_nikto_web_enumeration.png

14. Directory and Resource Enumeration – Gobuster

Gobuster was used to enumerate commonly accessible directories and files:

```
gobuster dir -u http://192.168.23.129 -w  
/usr/share/wordlists/dirb/common.txt
```

The scan identified resources including:

- dav/
- index.php
- index
- phpMyAdmin/
- phpinfo.php
- phpinfo
- test/
- twiki/

Several resources returned HTTP 403 responses, including:

- .htaccess
- .htpasswd
- cgi-bin
- server-status

These 403 responses indicate that access was denied by the web server and were therefore not treated as confirmed exposure.

Evidence: 11_gobuster_directory_enumeration.png

15. Reflected XSS Assessment

A controlled reflected XSS test was performed against the DVWA reflected XSS functionality.

A normal input was successfully reflected by the application.

A JavaScript test payload was then supplied.

The payload did not execute in the browser and no XSS alert was observed.

Result

Reflected XSS: Not Confirmed

The test was documented as an assessment activity rather than a confirmed vulnerability.

Evidence: 12_reflected_xss_test.png

16. Stored XSS Assessment

The DVWA stored XSS functionality was tested using a normal message followed by a controlled JavaScript test payload.

The baseline message was successfully stored and displayed.

The JavaScript payload did not execute and no browser alert was observed.

Result

Stored XSS: Not Confirmed

Evidence: 13_stored_xss_test.png

17. SQL Injection Assessment

A baseline request using User ID:

1

successfully returned the corresponding user record.

A controlled SQL injection test was then performed using:

1' OR '1'='1

The response continued to return only the original user record.

No evidence of expanded query results or successful SQL query manipulation was observed.

Result

SQL Injection: Not Confirmed

Evidence: 14_sql_injection_test.png

18. File Upload Assessment

The file upload functionality was reviewed as part of the application mapping process.

However, the upload test was not completed successfully.

Therefore:

No file-upload vulnerability is claimed in this report.

Additional controlled testing would be required to make a security conclusion regarding this functionality.

19. OWASP Top 10 Mapping

Finding	Evidence / Tool	OWASP Category	Risk
Outdated Apache/PHP	Nikto	A06 – Vulnerable and Outdated Components	High
Exposed phpMyAdmin	Nikto/Gobuster	A05 – Security Misconfiguration	High
Directory Listing	Nikto/Gobuster	A05 – Security Misconfiguration	Medium
Exposed phpinfo.php	Nikto/Gobuster	A05 – Security Misconfiguration	Medium
HTTP TRACE Enabled	Nikto	A05 – Security Misconfiguration	Medium
Missing Security Headers	Nikto	A05 – Security Misconfiguration	Medium
Authentication Review	DVWA	A07 – Identification and Authentication Failures	Informational
Session Management Review	Burp Suite	A07 – Identification and Authentication Failures	Informational
Reflected XSS	DVWA	A03 – Injection	Not Confirmed

Stored XSS	DVWA	A03 – Injection	Not Confirmed
SQL Injection	DVWA	A03 – Injection	Not Confirmed

20. Risk Assessment

Finding	Likelihood	Impact	Overall Risk	Priority
Outdated Apache/PHP	High	High	High	P1
Exposed phpMyAdmin	Medium	High	High	P1
Directory Listing	Medium	Medium	Medium	P2
Exposed phpinfo.php	Medium	Medium	Medium	P2
HTTP TRACE Enabled	Medium	Medium	Medium	P2
Missing Security Headers	Medium	Medium	Medium	P2
Authentication Review	Low	Medium	Low/Informational	P3
Session Management Review	Low	Medium	Low/Informational	P3

21. Security Recommendations

21.1 Upgrade Outdated Software

Upgrade Apache, PHP and other server-side components to currently supported versions.

A regular patch-management process should be implemented.

21.2 Restrict phpMyAdmin

phpMyAdmin should not be publicly exposed.

Access should be restricted to authorized administrators using network controls and strong authentication.

21.3 Remove phpinfo.php

The `phpinfo.php` file can expose detailed PHP and server configuration information.

It should be removed from production environments.

21.4 Disable Directory Listing

Directory indexing should be disabled unless explicitly required.

21.5 Disable HTTP TRACE

HTTP TRACE should be disabled when it is not required by the application.

21.6 Implement Security Headers

Appropriate HTTP security headers should be configured, including:

- Content-Security-Policy
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy
- Strict-Transport-Security when HTTPS is correctly deployed

21.7 Strengthen Authentication

Recommended controls include:

- Strong password policies
- Rate limiting
- Account protection
- Secure authentication mechanisms
- Monitoring of repeated failed authentication attempts

21.8 Secure Session Management

Session cookies should use appropriate:

- Secure
- HttpOnly
- SameSite

attributes where applicable.

21.9 Prevent SQL Injection

Applications should use parameterized queries or prepared statements rather than constructing SQL statements directly from user input.

21.10 Prevent XSS

Applications should implement:

- Input validation
- Context-aware output encoding
- Secure templating
- Appropriate Content Security Policy controls

21.11 Remove Unnecessary Resources

Unnecessary test, development, documentation and administrative resources should be removed or restricted.

21.12 Continuous Security Testing

Security testing should be repeated after remediation and during major application changes.

22. Security Checklist

Security Control	Status
Supported Apache/PHP versions	✗ Requires remediation
phpMyAdmin restricted	✗ Requires remediation
phpinfo.php removed	✗ Requires remediation
Directory listing disabled	✗ Requires remediation
HTTP TRACE disabled	✗ Requires remediation
Security headers configured	✗ Requires remediation
HTTPS correctly configured	To be reviewed
Authentication rate limiting	To be reviewed
Session cookies securely configured	To be reviewed
Parameterized SQL queries	To be reviewed
XSS output encoding	To be reviewed
Unnecessary test resources removed	✗ Requires remediation

23. Evidence and Screenshots

The following screenshots provide supporting evidence for the assessment:

1. 01_host_discovery_nmap.png – Nmap host discovery
2. 02_service_version_scan.png – Nmap service/version scan
3. 03_dvwa_login.png – DVWA login
4. 04_dvwa_security_level_low.png – DVWA security level
5. 05_dvwa_application_mapping.png – Application modules
6. 06_burp_http_history.png – Burp Suite HTTP history
7. 07_authentication_valid.png – Valid authentication
8. 08_authentication_invalid.png – Invalid authentication
9. 09_session_management_burp.png – Session review
10. 10_nikto_web_enumeration.png – Nikto findings
11. 11_gobuster_directory_enumeration.png – Gobuster findings
12. 12_reflected_xss_test.png – Reflected XSS test
13. 13_stored_xss_test.png – Stored XSS test
14. 14_sql_injection_test.png – SQL Injection test

Security note: Public copies of the evidence should not expose passwords, session cookies, tokens, API keys or other sensitive information.

24. Conclusion

The Web Application Security Review successfully demonstrated a structured security assessment process against an authorized intentionally vulnerable web application.

The assessment identified important security weaknesses primarily related to outdated server components, exposed administrative and configuration resources, directory indexing, HTTP TRACE functionality and missing security headers.

The controlled reflected XSS, stored XSS and SQL Injection tests did not confirm those vulnerabilities during the performed testing. The file upload functionality was not fully tested and therefore no conclusion was made regarding its security.

The most important remediation priorities are upgrading outdated components, restricting administrative interfaces, removing unnecessary resources, disabling directory indexing and HTTP TRACE, and implementing appropriate security headers.

Following remediation, a repeat security assessment should be performed to verify that the identified weaknesses have been addressed.

25. Ethical and Authorization Statement

All testing described in this report was performed against an intentionally vulnerable laboratory environment under authorized control.

The target system 192.168.23.129 was part of an isolated VMware host-only laboratory network used for cybersecurity training and assessment.

The techniques described in this report must only be used against systems for which explicit authorization has been obtained.

No unauthorized external systems were targeted during this assessment.

END OF REPORT

Prepared By: Lakshmi Subhaja Kari

B.Tech – Cybersecurity

Web Application Security Review & Vulnerability Analysis

2026